Withdrawn NIST Technical Series Publication

Warning Notice

The attached publication has been withdrawn (archived) and is provided solely for historical purposes. It may have been superseded by another publication (indicated below).

Withdrawn Publication	
Series/Number	NIST Special Publication 800-53 Rev. 4
Title	Security and Privacy Controls for Federal Information Systems and Organizations
Publication Date(s)	April 2013 (including updates as of January 22, 2015)
Withdrawal Date	September 23, 2021
Withdrawal Note	SP 800-53 Rev. 4 is superseded in its entirety by SP 800-53 Rev. 5 (September 2020, including updates as of 12/10/20).

Superseding Publication(s) *(if applicable)*	
The attached publication has been **superseded by** the following publication(s):	
Series/Number	NIST Special Publication 800-53 Rev. 5
Title	Security and Privacy Controls for Information Systems and Organizations
Author(s)	Joint Task Force
Publication Date(s)	September 2020 (including updates as of December 10, 2020)
URL/DOI	https://doi.org/10.6028/NIST.SP.800-53r5

Additional Information *(if applicable)*	
Contact	Computer Security Division (Information Technology Laboratory)
Latest revision of the attached publication	
Related Information	https://csrc.nist.gov/projects/risk-management/sp800-53-controls https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
Withdrawal Announcement Link	

Date updated: September 23, 2021

National Institute of Standards and Technology
U.S. Department of Commerce

Step 1: *Categorize* the information system based on a FIPS Publication 199 impact assessment;[28]

Step 2: *Select* the applicable security control baseline based on the results of the security categorization and apply tailoring guidance (including the potential use of overlays);

Step 3: *Implement* the security controls and document the design, development, and implementation details for the controls;

Step 4: *Assess* the security controls to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system;[29]

Step 5: *Authorize* information system operation based on a determination of risk to organizational operations and assets, individuals, other organizations, and the Nation resulting from the operation and use of the information system and the decision that this risk is acceptable; and

Step 6: *Monitor* the security controls in the information system and environment of operation on an ongoing basis to determine control effectiveness, changes to the system/environment, and compliance to legislation, Executive Orders, directives, policies, regulations, and standards.

2.2 SECURITY CONTROL STRUCTURE

Security controls described in this publication have a well-defined organization and structure. For ease of use in the security control selection and specification process, controls are organized into eighteen *families*.[30] Each family contains security controls related to the general security topic of the family. A two-character identifier uniquely identifies security control families, for example, PS (Personnel Security). Security controls may involve aspects of policy, oversight, supervision, manual processes, actions by individuals, or automated mechanisms implemented by information systems/devices. Table 1 lists the security control families and the associated family identifiers in the security control catalog.[31]

TABLE 1: SECURITY CONTROL IDENTIFIERS AND FAMILY NAMES

ID	FAMILY	ID	FAMILY
AC	Access Control	MP	Media Protection
AT	Awareness and Training	PE	Physical and Environmental Protection
AU	Audit and Accountability	PL	Planning
CA	Security Assessment and Authorization	PS	Personnel Security
CM	Configuration Management	RA	Risk Assessment
CP	Contingency Planning	SA	System and Services Acquisition
IA	Identification and Authentication	SC	System and Communications Protection
IR	Incident Response	SI	System and Information Integrity
MA	Maintenance	PM	Program Management

[28] CNSS Instruction 1253 provides security categorization guidance for national security systems.

[29] NIST Special Publication 800-53A provides guidance on assessing the effectiveness of security controls.

[30] Of the eighteen security control families in NIST Special Publication 800-53, seventeen families are described in the security control catalog in Appendix F, and are closely aligned with the seventeen minimum security requirements for federal information and information systems in FIPS Publication 200. One additional family (Program Management [PM] family) provides controls for information security programs required by FISMA. This family, while not specifically referenced in FIPS Publication 200, provides security controls at the organization level rather than the information system level. See Appendix G for a description of and implementation guidance for the PM controls.

[31] *Privacy controls* listed in Appendix J, have an organization and structure similar to security controls, including the use of two-character identifiers for the eight privacy families.

FAMILY: ACCESS CONTROL

AC-1 ACCESS CONTROL POLICY AND PROCEDURES

Control: The organization:

a. Develops, documents, and disseminates to [*Assignment: organization-defined personnel or roles*]:

   1. An access control policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and

   2. Procedures to facilitate the implementation of the access control policy and associated access controls; and

b. Reviews and updates the current:

   1. Access control policy [*Assignment: organization-defined frequency*]; and

   2. Access control procedures [*Assignment: organization-defined frequency*].

Supplemental Guidance: This control addresses the establishment of policy and procedures for the effective implementation of selected security controls and control enhancements in the AC family. Policy and procedures reflect applicable federal laws, Executive Orders, directives, regulations, policies, standards, and guidance. Security program policies and procedures at the organization level may make the need for system-specific policies and procedures unnecessary. The policy can be included as part of the general information security policy for organizations or conversely, can be represented by multiple policies reflecting the complex nature of certain organizations. The procedures can be established for the security program in general and for particular information systems, if needed. The organizational risk management strategy is a key factor in establishing policy and procedures. Related control: PM-9.

Control Enhancements: None.

References: NIST Special Publications 800-12, 800-100.

Priority and Baseline Allocation:

P1	**LOW** AC-1	**MOD** AC-1	**HIGH** AC-1

AC-2 ACCOUNT MANAGEMENT

Control: The organization:

a. Identifies and selects the following types of information system accounts to support organizational missions/business functions: [*Assignment: organization-defined information system account types*];

b. Assigns account managers for information system accounts;

c. Establishes conditions for group and role membership;

d. Specifies authorized users of the information system, group and role membership, and access authorizations (i.e., privileges) and other attributes (as required) for each account;

e. Requires approvals by [*Assignment: organization-defined personnel or roles*] for requests to create information system accounts;

f. Creates, enables, modifies, disables, and removes information system accounts in accordance with [*Assignment: organization-defined procedures or conditions*];

g. Monitors the use of information system accounts;

issues, and other potential security problems. Dynamic code analysis employs run-time tools to help to ensure that security functionality performs in the manner in which it was designed. A specialized type of dynamic analysis, known as fuzz testing, induces program failures by deliberately introducing malformed or random data into software programs. Fuzz testing strategies derive from the intended use of applications and the functional and design specifications for the applications. To understand the scope of dynamic code analysis and hence the assurance provided, organizations may also consider conducting code coverage analysis (checking the degree to which the code has been tested using metrics such as percent of subroutines tested or percent of program statements called during execution of the test suite) and/or concordance analysis (checking for words that are out of place in software code such as non-English language words or derogatory terms).

References: ISO/IEC 15408; NIST Special Publication 800-53A;
Web: http://nvd.nist.gov, http://cwe.mitre.org, http://cve.mitre.org, http://capec.mitre.org.

Priority and Baseline Allocation:

P1	**LOW** Not Selected	**MOD** SA-11	**HIGH** SA-11

SA-12 SUPPLY CHAIN PROTECTION

Control: The organization protects against supply chain threats to the information system, system component, or information system service by employing [*Assignment: organization-defined security safeguards*] as part of a comprehensive, defense-in-breadth information security strategy.

Supplemental Guidance: Information systems (including system components that compose those systems) need to be protected throughout the system development life cycle (i.e., during design, development, manufacturing, packaging, assembly, distribution, system integration, operations, maintenance, and retirement). Protection of organizational information systems is accomplished through threat awareness, by the identification, management, and reduction of vulnerabilities at each phase of the life cycle and the use of complementary, mutually reinforcing strategies to respond to risk. Organizations consider implementing a standardized process to address supply chain risk with respect to information systems and system components, and to educate the acquisition workforce on threats, risk, and required security controls. Organizations use the acquisition/procurement processes to require supply chain entities to implement necessary security safeguards to: (i) reduce the likelihood of unauthorized modifications at each stage in the supply chain; and (ii) protect information systems and information system components, prior to taking delivery of such systems/components. This control also applies to information system services. Security safeguards include, for example: (i) security controls for development systems, development facilities, and external connections to development systems; (ii) vetting development personnel; and (iii) use of tamper-evident packaging during shipping/warehousing. Methods for reviewing and protecting development plans, evidence, and documentation are commensurate with the security category or classification level of the information system. Contracts may specify documentation protection requirements. Related controls: AT-3, CM-8, IR-4, PE-16, PL-8, SA-3, SA-4, SA-8, SA-10, SA-14, SA-15, SA-18, SA-19, SC-29, SC-30, SC-38, SI-7.

Control Enhancements:

(1) *SUPPLY CHAIN PROTECTION | ACQUISITION STRATEGIES / TOOLS / METHODS*

The organization employs [*Assignment: organization-defined tailored acquisition strategies, contract tools, and procurement methods*] for the purchase of the information system, system component, or information system service from suppliers.

Supplemental Guidance: The use of acquisition and procurement processes by organizations early in the system development life cycle provides an important vehicle to protect the supply chain. Organizations use available all-source intelligence analysis to inform the tailoring of acquisition strategies, tools, and methods. There are a number of different tools and techniques available (e.g., obscuring the end use of an information system or system

APPENDIX J

PRIVACY CONTROL CATALOG

PRIVACY CONTROLS, ENHANCEMENTS, AND SUPPLEMENTAL GUIDANCE

The need to protect an individual's privacy is as important today as it was in 1974 when the Privacy Act first sought to balance the government's need to collect information from an individual with a citizen's right to be notified as to how that information was being used, collected, maintained, and disposed of after the requisite period of use. These concerns are also shared in the private sector, where healthcare, financial, and other services continue to be delivered via the web with increasingly higher levels of personalization. The proliferation of social media, Smart Grid, mobile, and cloud computing, as well as the transition from structured to unstructured data and metadata environments, have added significant complexities and challenges for federal organizations in safeguarding privacy. These challenges extend well beyond the traditional information technology security view of protecting privacy which focused primarily on ensuring confidentiality. Now there are greater implications with respect to controlling the integrity of an individual's information, and with ensuring that an individual's information is available on demand. The challenging landscape requires federal organizations to expand their view of privacy, in order to meet citizen expectations of privacy that go beyond information security.

Privacy, with respect to personally identifiable information (PII),[119] is a core value that can be obtained only with appropriate legislation, policies, procedures, and associated controls to ensure compliance with requirements. Protecting the privacy of individuals and their PII that is collected, used, maintained, shared, and disposed of by programs and information systems, is a fundamental responsibility of federal organizations. Privacy also involves each individual's right to decide when and whether to share personal information, how much information to share, and the particular circumstances under which that information can be shared. In today's digital world, effective privacy for individuals depends on the safeguards employed within the information systems that are processing, storing, and transmitting PII and the environments in which those systems operate. Organizations cannot have effective privacy without a basic foundation of information security. Privacy is more than security, however, and includes, for example, the principles of transparency, notice, and choice.

This appendix provides a structured set of controls for protecting privacy and serves as a roadmap for organizations to use in identifying and implementing privacy controls concerning the entire life cycle of PII, whether in paper or electronic form. The controls focus on information privacy as a value distinct from, but highly interrelated with, information security. Privacy controls are

[119] OMB Memorandum 07-16 defines PII as information which can be used to distinguish or trace an individual's identity such as their name, social security number, biometric records, etc., alone, or when combined with other personal or identifying information which is linked or linkable to a specific individual, such as date and place of birth, mother's maiden name, etc. OMB Memorandum 10-22 further states that "the definition of PII is not anchored to any single category of information or technology. Rather, it requires a case-by-case assessment of the specific risk that an individual can be identified by examining the context of use and combination of data elements. In performing this assessment, it is important for agencies to recognize that non-PII can become PII, whenever additional information is made publicly available, in any medium and from any source that, when combined with other available information, could be used to identify an individual." NIST Special Publication 800-122 also includes a definition of PII that differs from this appendix because it was focused on the security objective of confidentiality and not privacy in the broad sense. Organizational definitions of PII may vary based on the consideration of additional regulatory requirements. The privacy controls in this appendix apply regardless of the definition of PII by organizations.

the administrative, technical, and physical safeguards employed within organizations to protect and ensure the proper handling of PII.[120] Organizations may also engage in activities that do not involve the collection and use of PII, but may nevertheless raise privacy concerns and associated risk. The privacy controls are equally applicable to those activities and can be used to analyze the privacy risk and mitigate such risk when necessary.

The privacy controls in this appendix are based on the Fair Information Practice Principles (FIPPs)[121] embodied in the Privacy Act of 1974, Section 208 of the E-Government Act of 2002, and Office of Management and Budget (OMB) policies. The FIPPs are designed to build public trust in the privacy practices of organizations and to help organizations avoid tangible costs and intangible damages from privacy incidents. There are eight privacy control families, each aligning with one of the FIPPs. The privacy families can be implemented at the organization, department, agency, component, office, program, or information system level, under the leadership and oversight of the Senior Agency Official for Privacy (SAOP)/Chief Privacy Officer (CPO)[122] and in coordination with the Chief Information Security Officer, Chief Information Officer, program officials, legal counsel, and others as appropriate. Table J-1 provides a summary of the privacy controls by family in the privacy control catalog.

TABLE J-1: SUMMARY OF PRIVACY CONTROLS BY FAMILY

ID	PRIVACY CONTROLS
AP	**Authority and Purpose**
AP-1	Authority to Collect
AP-2	Purpose Specification
AR	**Accountability, Audit, and Risk Management**
AR-1	Governance and Privacy Program
AR-2	Privacy Impact and Risk Assessment
AR-3	Privacy Requirements for Contractors and Service Providers
AR-4	Privacy Monitoring and Auditing
AR-5	Privacy Awareness and Training
AR-6	Privacy Reporting
AR-7	Privacy-Enhanced System Design and Development
AR-8	Accounting of Disclosures
DI	**Data Quality and Integrity**
DI-1	Data Quality
DI-2	Data Integrity and Data Integrity Board
DM	**Data Minimization and Retention**
DM-1	Minimization of Personally Identifiable Information
DM-2	Data Retention and Disposal

[120] In 2010, the Federal CIO Council Privacy Committee issued a framework for designing and implementing a privacy program entitled *Best Practices: Elements of a Federal Privacy Program (Elements White Paper)*. The privacy controls in this appendix mirror a number of the elements included in the paper. Organizations can use the privacy controls and the guidance in the paper to develop an organization-wide privacy program or enhance an already existing program.

[121] The FIPPs are widely accepted in the United States and internationally as a general framework for privacy and are reflected in other federal and international laws and policies. In a number of organizations, FIPPs serve as the basis for analyzing privacy risks and determining appropriate mitigation strategies. The Federal Enterprise Architecture Security and Privacy Profile (FEA-SPP) also provided information and materials in development of the privacy controls.

[122] All federal agencies and departments designate an SAOP/CPO as the senior organizational official with the overall organization-wide responsibility for information privacy issues. OMB Memorandum 05-08 provides guidance for the designation of SAOPs/CPOs. The term SAOP/CPO as used in this appendix means an organization's senior privacy leader, whose job title may vary from organization to organization.

ID	PRIVACY CONTROLS
DM-3	Minimization of PII Used in Testing, Training, and Research
IP	**Individual Participation and Redress**
IP-1	Consent
IP-2	Individual Access
IP-3	Redress
IP-4	Complaint Management
SE	**Security**
SE-1	Inventory of Personally Identifiable Information
SE-2	Privacy Incident Response
TR	**Transparency**
TR-1	Privacy Notice
TR-2	System of Records Notices and Privacy Act Statements
TR-3	Dissemination of Privacy Program Information
UL	**Use Limitation**
UL-1	Internal Use
UL-2	Information Sharing with Third Parties

There is a strong similarity between the structure of the privacy controls in this appendix and the structure of the security controls in Appendices F and G. For example, the control AR-1 (Governance and Privacy Program) requires organizations to develop privacy plans that can be implemented at the organizational or program level. These plans can also be used in conjunction with security plans to provide an opportunity for organizations to select the appropriate set of security and privacy controls in accordance with organizational mission/business requirements and the environments in which the organizations operate. Incorporating the fundamental concepts associated with managing information security risk helps to ensure that the employment of privacy controls is carried out in a cost-effective and risk-based manner while simultaneously meeting compliance requirements. Standardized privacy controls and assessment procedures (developed to evaluate the effectiveness of the controls) will provide a more disciplined and structured approach for satisfying federal privacy requirements and demonstrating compliance with those requirements.

In summary, the Privacy Appendix achieves several important objectives. The appendix:

- Provides a structured set of privacy controls, based on best practices, that helps organizations comply with applicable federal laws, Executive Orders, directives, instructions, regulations, policies, standards, guidance, and organization-specific issuances;
- Establishes a linkage and relationship between privacy and security controls for purposes of enforcing respective privacy and security requirements that may overlap in concept and in implementation within federal information systems, programs, and organizations;
- Demonstrates the applicability of the NIST Risk Management Framework in the selection, implementation, assessment, and ongoing monitoring of privacy controls deployed in federal information systems, programs, and organizations; and
- Promotes closer cooperation between privacy and security officials within the federal government to help achieve the objectives of senior leaders/executives in enforcing the requirements in federal privacy legislation, policies, regulations, directives, standards, and guidance.